

Introduction à la Sécurité Informatique et des Réseaux

Labo 1 — Modélisation des Menaces — Trilogie CIA

Scénario : Hôpital National du Wakanda (HNW)

Groupe :

Membre du groupe :

-Ibrahima Watt

-Sekou Diao

-Bassirou Diao

-Adama Seck

Partie A — Analyse de la Trilogie CIA

Pour chaque scénario, nous identifions si la Confidentialité (C), l'Intégrité (I) et/ou la Disponibilité (D) sont affectées, avec justification.

Scénario	C — Confidentialité	I — Intégrité	D — Disponibilité
Un attaquant devine le mot de passe du Dr Seck et consulte des dossiers patients	Affectée <i>Des données patients confidentielles sont lues par un tiers non autorisé.</i>	☐ Non affectée <i>Les données ne sont pas modifiées, seulement consultées.</i>	☐ Non affectée <i>Le système reste disponible.</i>
Un employé mécontent modifie la liste d'allergies d'un patient dans SanteNum	☐ Non affectée <i>Pas de divulgation externe.</i>	Affectée <i>Les données médicales sont falsifiées, menaçant l'exactitude du dossier.</i>	☐ Non affectée <i>L'accès au système reste possible.</i>
Un ransomware chiffre la base de données du DME, rendant les dossiers inaccessibles	Affectée <i>L'attaquant accède aux données avant/pendant le chiffrement.</i>	Affectée <i>Le chiffrement altère l'intégrité des fichiers stockés.</i>	Affectée <i>Les dossiers deviennent inaccessibles au personnel soignant.</i>
Le système de laboratoire est saturé de requêtes et devient indisponible pendant 6 heures (attaque DDoS)	☐ Non affectée <i>Aucune donnée n'est exposée.</i>	☐ Non affectée <i>Les données ne sont pas modifiées.</i>	Affectée <i>Le service est hors ligne pendant 6h, bloquant les analyses.</i>
Un agent interne transmet des résultats de tests VIH à l'employeur d'un patient	Affectée <i>Des données médicales ultra-sensibles sont divulguées sans consentement.</i>	☐ Non affectée <i>Les données transmises sont exactes, sans falsification.</i>	☐ Non affectée <i>Le système reste opérationnel.</i>
Les dosages de médicaments sont altérés en transit par une attaque de l'homme du milieu (MitM)	Affectée <i>L'attaquant intercepte les communications et peut lire les données.</i>	Affectée <i>Les valeurs de dosage sont modifiées lors de la transmission.</i>	☐ Non affectée <i>Le système continue de fonctionner, même avec des données altérées.</i>
(Scénario libre) Un ancien employé utilise ses identifiants non révoqués pour exporter la base de données patients	Affectée <i>Des milliers de dossiers patients sont extraits par une personne non autorisée.</i>	☐ Non affectée <i>Les données exportées ne sont pas modifiées.</i>	☐ Non affectée <i>Le système reste disponible pour les utilisateurs légitimes.</i>

Q1 — Propriété CIA la plus souvent violée

Réponse : La Confidentialité est la propriété la plus fréquemment violée (4 scénarios sur 7 : accès non autorisé aux dossiers, transmission des résultats VIH, ransomware, MitM, et l'identifiant non révoqué).

Pourquoi ce système est-il particulièrement vulnérable dans le contexte d'un hôpital public africain ?

- Ressources limitées : les hôpitaux publics africains disposent souvent de budgets informatiques insuffisants pour déployer des solutions de sécurité robustes (MFA, DLP, SIEM).
- Faible culture de cybersécurité : le personnel médical est peu formé aux risques numériques ; les mots de passe faibles et le partage de comptes sont courants.
- Dépendance à des fournisseurs cloud régionaux dont le niveau de sécurité peut être inférieur aux standards internationaux.
- Infrastructure hybride vulnérable : la synchronisation nocturne non chiffrée via un ancien serveur on-site constitue un vecteur d'interception évident.
- Valeur élevée des données de santé sur le marché noir (assurances, chantage, discrimination) — cible attractive pour les attaquants.

Q2 — Scénario violent simultanément les trois propriétés CIA

Scénario identifié : L'attaque par ransomware qui chiffre la base de données du DME.

- Confidentialité : avant de chiffrer, les opérateurs du ransomware exfiltrent souvent les données (double extorsion). L'attaquant a potentiellement accès à l'intégralité des dossiers patients.
- Intégrité : le chiffrement rend les fichiers illisibles et inutilisables — leur état est altéré, ils ne correspondent plus à leur forme originale valide.
- Disponibilité : les médecins, infirmiers et personnels administratifs ne peuvent plus consulter les dossiers patients, paralysant les soins cliniques.

Ce scénario représente donc la menace la plus grave car il compromet simultanément l'ensemble de la trilogie CIA, avec des conséquences potentiellement mortelles pour les patients.

Partie B — Faiblesses, Vulnérabilités et Exploits

Rappel des définitions :

- Faiblesse : absence d'un contrôle de sécurité qui devrait exister (conception ou configuration).
- Vulnérabilité : faille identifiée et exploitable dans un système (peut avoir un CVE).
- Exploit : code ou technique permettant de tirer parti d'une vulnérabilité spécifique.
- Attaque : action offensive intentionnelle visant à compromettre un système.

Élément	Catégorie	Justification
A. La page de connexion de SanteNum n'a pas de mécanisme de verrouillage de compte	Faiblesse	Absence d'un contrôle de sécurité qui devrait exister — aucun CVE assigné, c'est un manque de conception.
B. Un attaquant exécute un script de bourrage de credentials contre SanteNum	Attaque	Action offensive concrète et intentionnelle menée par un acteur malveillant contre le système.
C. La synchronisation nocturne utilise un partage réseau non chiffré	Vulnérabilité	Faiblesse exploitable et identifiable : les données transitent en clair, exposées

Élément	Catégorie	Justification
		à l'interception.
D. Le mot de passe faible d'un employé est cracké par force brute	Exploit	L'attaquant tire parti d'une faiblesse (mot de passe faible) pour compromettre un accès — c'est l'exploitation réussie.
E. Le serveur web tourne sur une version Apache obsolète avec une CVE connue	Vulnérabilité	CVE documentée = vulnérabilité reconnue, répertoriée, et potentiellement exploitable par n'importe qui.
F. Un agent malveillant injecte du SQL dans le champ de recherche pour extraire la BD	Attaque	Acte malveillant actif visant à compromettre le système via une technique d'injection SQL.

Partie C — Phases d'Attaque

Analyse du récit d'attaque selon les 5 phases du cycle d'attaque (Cyber Kill Chain).

1. Reconnaissance	
1.	Publication sur les réseaux sociaux professionnels par le personnel (fonctions, outils numériques utilisés).
2.	Appels suspects reçus par le service informatique de personnes se faisant passer pour des techniciens du fournisseur cloud (ingénierie sociale pour identifier les logiciels utilisés).
3.	Collecte passive d'informations sur l'environnement technologique de l'HNW (SanteNum, fournisseur cloud Azania).
2. Infiltration / Armement & Livraison	
1.	Envoi d'un e-mail de phishing ciblé à Fatoumata Diallo (agent facturation), prétendant provenir d'un partenaire médical connu.
2.	Le message contient un fichier joint malveillant (pièce jointe piégée) lié à une fausse mise à jour des procédures.
3.	Fatoumata ouvre le fichier depuis son poste professionnel — déclenchement du vecteur d'infection.
4.	Exploitation du compte avec des droits d'accès aux données financières et d'assurance maladie.
3. Persistance & Mouvement latéral	
1.	Ralentissement de certains ordinateurs — indicateur d'activité malveillante en arrière-plan (malware actif).
2.	Connexions inhabituelles détectées tard la nuit — l'attaquant agit hors des heures de bureau pour éviter la détection.
3.	Comptes utilisateurs accédant à des dossiers inhabituels — mouvement latéral vers d'autres ressources (DME, pharmacie, labo).
4.	Phase silencieuse permettant à l'attaquant de cartographier le réseau, d'escalader les privilèges et de préparer la charge finale.
4. Exécution de l'attaque (Impact)	
1.	Chiffrement du système par ransomware : les dossiers patients, analyses de laboratoire et le système de rendez-vous deviennent inaccessibles.

2.	Message de rançon affiché sur plusieurs écrans, exigeant un paiement pour restaurer l'accès.
3.	Perturbation majeure des services cliniques (médecins, laboratoire, administration) — menace directe pour la sécurité des patients.
4.	Violation simultanée des trois piliers CIA : C (accès aux données), I (chiffrement des fichiers), D (inaccessibilité des systèmes).
5. Dissimulation & Dénier plausible	
1.	Suppression des journaux d'activité par l'attaquant pour effacer les traces de l'intrusion.
2.	Connexions provenant de serveurs situés dans plusieurs pays — utilisation d'un réseau de rebond pour masquer l'origine réelle.
3.	Usurpation des adresses IP du ministère de la santé du Wakanda — faux positifs conçus pour détourner les soupçons vers une institution légitime.
4.	Technique de fausse bannière (false flag) : faire croire que l'attaque vient d'une source gouvernementale pour compliquer l'investigation et retarder la réponse.

Q3 — Synthèse et observations

Phases difficiles à distinguer : La frontière entre Infiltration et Persistance/Mouvement latéral peut être floue : l'ouverture du fichier par Fatoumata marque l'infiltration initiale, mais c'est la phase silencieuse suivante (connexions nocturnes, ralentissements) qui correspond au déploiement et à l'expansion du malware.

Observation clé : L'usurpation des adresses IP du ministère de la santé est une technique sophistiquée de fausse bannière (false flag) qui rend l'attribution difficile et retarde la réponse aux incidents — caractéristique d'un attaquant expérimenté, probablement un groupe APT (Advanced Persistent Threat).

Réflexion de groupe — Préparation à la présentation

1. Menace la plus grave

L'attaque par ransomware est la plus grave car elle compromet simultanément les 3 piliers CIA, paralyse les soins médicaux (risque vital pour les patients), et son impact est immédiat, visible et difficile à réverser sans sauvegardes. Dans un hôpital africain avec des ressources limitées, payer la rançon n'est souvent pas une option, et la reconstruction peut prendre des semaines.

2. Vulnérabilité choisie + contre-mesures

Vulnérabilité : C — Synchronisation nocturne via un partage réseau non chiffré.

Contre-mesure technique : Chiffrer toutes les communications de synchronisation avec TLS 1.3 ou VPN IPsec. Mettre en place une authentification mutuelle entre le serveur on-site et le cloud (certificats clients).

Contre-mesure organisationnelle : Établir une politique de sécurité des transferts de données imposant le chiffrement de bout en bout pour tout transfert de données médicales, avec audit trimestriel de conformité. Former l'administrateur Seydou Coulibaly aux bonnes pratiques de sécurisation des flux réseau.

3. Phases difficiles à distinguer

Les phases de Persistance et d'Exécution sont proches dans le récit : les ralentissements et connexions nocturnes pourraient être interprétés soit comme la fin de l'infiltration, soit comme le début de l'exécution. En pratique, la distinction repose sur l'intention : la persistance vise à s'installer durablement, l'exécution à déclencher l'impact final.

4. Priorité CIA selon le rôle

DSI de l'HNW : Prioriserait la Disponibilité — un hôpital doit fonctionner 24h/24. L'indisponibilité du DME peut directement menacer des vies (accès aux allergies, traitements en cours, résultats d'analyses urgents).

Perspective d'un patient : Prioriserait la Confidentialité — la divulgation de données médicales sensibles (VIH, psychiatrie, addictions) peut entraîner discrimination, perte d'emploi ou stigmatisation sociale. Dans le contexte africain, où les protections légales des données personnelles sont encore émergentes, cette vulnérabilité est particulièrement préoccupante.